

Network and Cyber Security

Bachelor in Computer Engineering

Er. Anuj Sherchan
Assistant Professor

Unit 5: Cyber(Web)Security

- Outline:
- 5.1 Approaches to Web Security
- 5.2 Secure Socket Layer Architecture ,Transport Layer Security
- 5.3 IPSec
 - 5.3.1 IPSec Transport Mode
 - 5.3.2 IPSec Tunnel Mode
- 5.4 Email Security
 - 5.4.1 Pretty Good Security
 - 5.4.2 S/MIME

Introduction

- **What is Web Security?**
- Web security is about keeping websites, servers, users, and devices safe from cyberattacks that come through the internet.
- These attacks can include things like viruses, fake emails (phishing), and other harmful activities that can steal or leak important information.
- To stay protected, web security uses different tools and methods, such as firewalls, systems that block suspicious activity, filters that block dangerous websites, and antivirus software.
- It also covers the security of Web Apps, APIs, and cloud systems to keep everything running safely online.
- **For example-** when you are transferring data between client and web server and you have to protect that data, that security of data is your web security.

Introduction

- Cyber security Fundamentals –
- **Confidentiality:** Confidentiality is about preventing the disclosure of data to unauthorized parties.
- It also means trying to keep the identity of authorized parties involved in sharing and holding data private and anonymous.
- Often confidentiality is compromised by cracking poorly encrypted data, Man-in-the-middle (MITM) attacks, disclosing sensitive data. Standard measures to establish confidentiality include:
 - Data encryption
 - Two-factor authentication
 - Biometric verification
 - Security tokens

Introduction

- **Integrity**
- Integrity refers to protecting information from being modified by unauthorized parties.
- Standard measures to guarantee integrity include:
- Cryptographic checksums
- Using file permissions
- Uninterrupted power supplies
- Data backups

Introduction

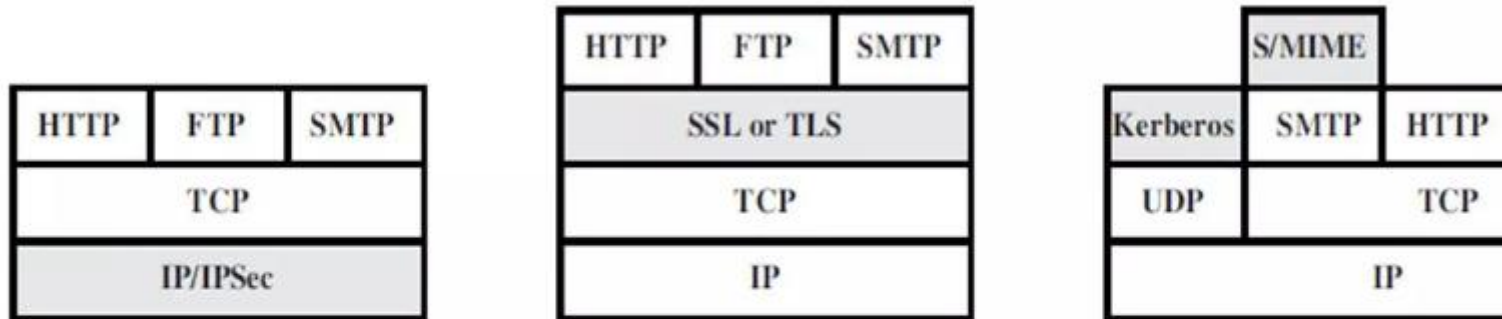
- **Availability**
- Availability is making sure that authorized parties are able to access the information when needed.
- Standard measures to guarantee availability include:
- Backing up data to external drives
- Implementing firewalls
- Having backup power supplies
- Data redundancy

Web Security Threats

	Threats	Consequences	Countermeasures
Integrity	• Modification of user data • Trojan horse browser • Modification of memory • Modification of message traffic in transit	• Loss of information • Compromise of machine • Vulnerability to all other threats	Cryptographic checksums
Confidentiality	• Eavesdropping on the net • Theft of info from server • Theft of data from client • Info about network configuration • Info about which client talks to server	• Loss of information • Loss of privacy	Encryption, Web proxies
Denial of Service	• Killing of user threads • Flooding machine with bogus requests • Filling up disk or memory • Isolating machine by DNS attacks	• Disruptive • Annoying • Prevent user from getting work done	Difficult to prevent
Authentication	• Impersonation of legitimate users • Data forgery	• Misrepresentation of user • Belief that false information is valid	Cryptographic techniques

Web Security Threats

Web Security Threats



- One way to provide Web security is to use IP security (IPsec).
- The advantage of using IPsec is that it is transparent to end users and applications and provides a general-purpose solution.
- IPsec includes a filtering capability so that only selected traffic need incur the overhead of IPsec processing.

Types of Cyber Attacks

- A cyber-attack is an exploitation of computer systems and networks.
- It uses malicious code to alter computer code, logic or data and lead to cybercrimes, such as information and identity theft.
- Cyber-attacks can be classified into the following categories:
- **1) Web-based attacks**
- **2) System-based attacks**
- **Web-based attacks**
- These are the attacks which occur on a website or web applications.
- Some of the important web-based attacks are as follows:

Types of Cyber Attacks

- **Injection attacks**
- It is the attack in which some data will be injected into a web application to manipulate the application and fetch the required information.
- Example- SQL Injection, code Injection, log Injection, XML Injection etc.
- **DNS Spoofing**
- DNS Spoofing is a type of computer security hacking.
- Whereby a data is introduced into a DNS resolver's cache causing the name server to return an incorrect IP address, diverting traffic to the attackers computer or any other computer.
- The DNS spoofing attacks can go on for a long period of time without being detected and can cause serious security issues.

Types of Cyber Attacks

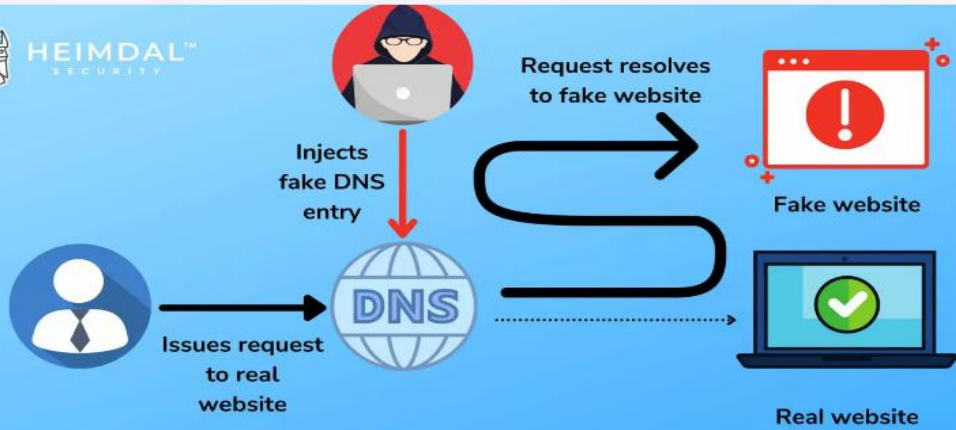
- **Session Hijacking**
 - It is a security attack on a user session over a protected network.
 - Web applications create cookies to store the state and user sessions.
 - By stealing the cookies, an attacker can have access to all of the user data.
- **Phishing**
 - Phishing is a type of attack which attempts to steal sensitive information like user login credentials and credit card number.
 - It occurs when an attacker is masquerading as a trustworthy entity in electronic communication.

Types of Cyber Attacks

- **Brute force**
 - It is a type of attack which uses a trial and error method.
 - This attack generates a large number of guesses and validates them to obtain actual data like user password and personal identification number.
 - This attack may be used by criminals to crack encrypted data, or by security analysts to test an organization's network security.
- **Denial of Service**
 - It is an attack which meant to make a server or network resource unavailable to the users.
 - It accomplishes this by flooding the target with traffic or sending it information that triggers a crash.
 - It uses the single system and single internet connection to attack a server.
 - It can be classified into the following:



HEIMDAL™
SECURITY



eset

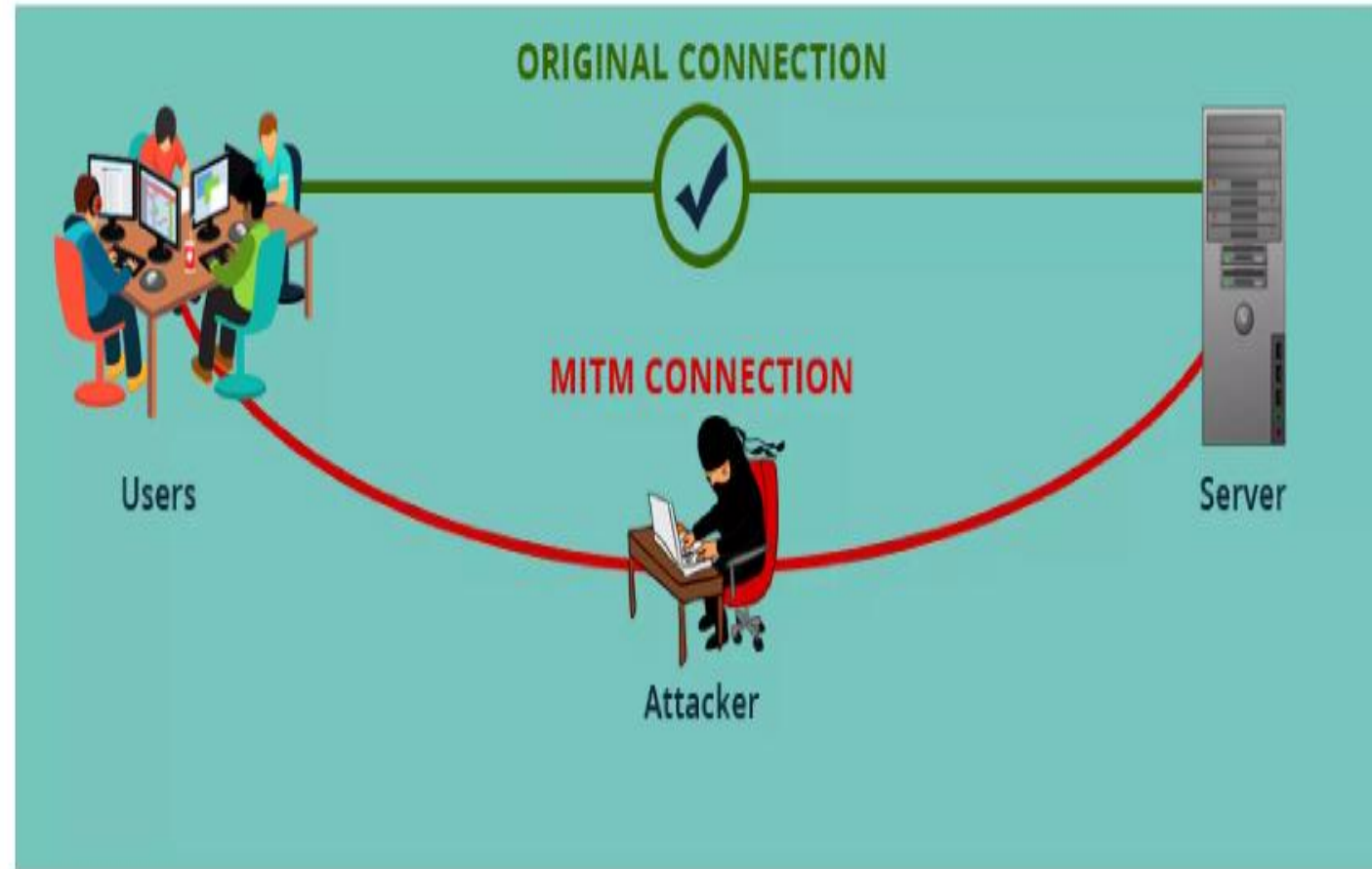
⚠️ Potential phishing attempt

This [web page](#) tries to trick visitors into submitting sensitive personal information such as login data or credit card numbers.

Go back to the previous page?

Go back

Ignore threat



Types of Cyber Attacks

- **Volume-based attacks**-Its goal is to saturate the bandwidth of the attacked site, and is measured in bit per second.
- **Protocol attacks**- It consumes actual server resources, and is measured in a packet.
- **Application layer attacks**- Its goal is to crash the web server and is measured in request per second.
- **Dictionary attacks**
 - This type of attack stored the list of a commonly used password and validated them to get original password.
- **URL Interpretation**
 - It is a type of attack where we can change the certain parts of a URL, and one can make a web server to deliver web pages for which he is not authorized to browse.

Types of Cyber Attacks

- **File Inclusion attacks**
- It is a type of attack that allows an attacker to access unauthorized or essential files which is available on the web server or to execute malicious files on the web server by making use of the include functionality.
- **Man in the middle attacks**
- It is a type of attack that allows an attacker to intercepts the connection between client and server and acts as a bridge between them.
- Due to this, an attacker will be able to read, insert and modify the data in the intercepted connection.

Types of Cyber Attacks

- **System-based attacks**
- These are the attacks which are intended to compromise a computer or a computer network.
- Some of the important system-based attacks are as follows
- **Virus**
- It is a type of malicious software program that spread throughout the computer files without the knowledge of a user.
- It is a self-replicating malicious computer program that replicates by inserting copies of itself into other computer programs when executed.
- It can also execute instructions that cause harm to the system.

Types of Cyber Attacks

- **Worm**

- It is a type of malware whose primary function is to replicate itself to spread to uninfected computers.
- It works same as the computer virus.
- Worms often originate from email attachments that appear to be from trusted senders.

- **Trojan horse**

- It is a malicious program that occurs unexpected changes to computer setting and unusual activity, even when the computer should be idle.
- It misleads the user of its true intent.
- It appears to be a normal application but when opened/executed some malicious code will run in the background.

Types of Cyber Attacks

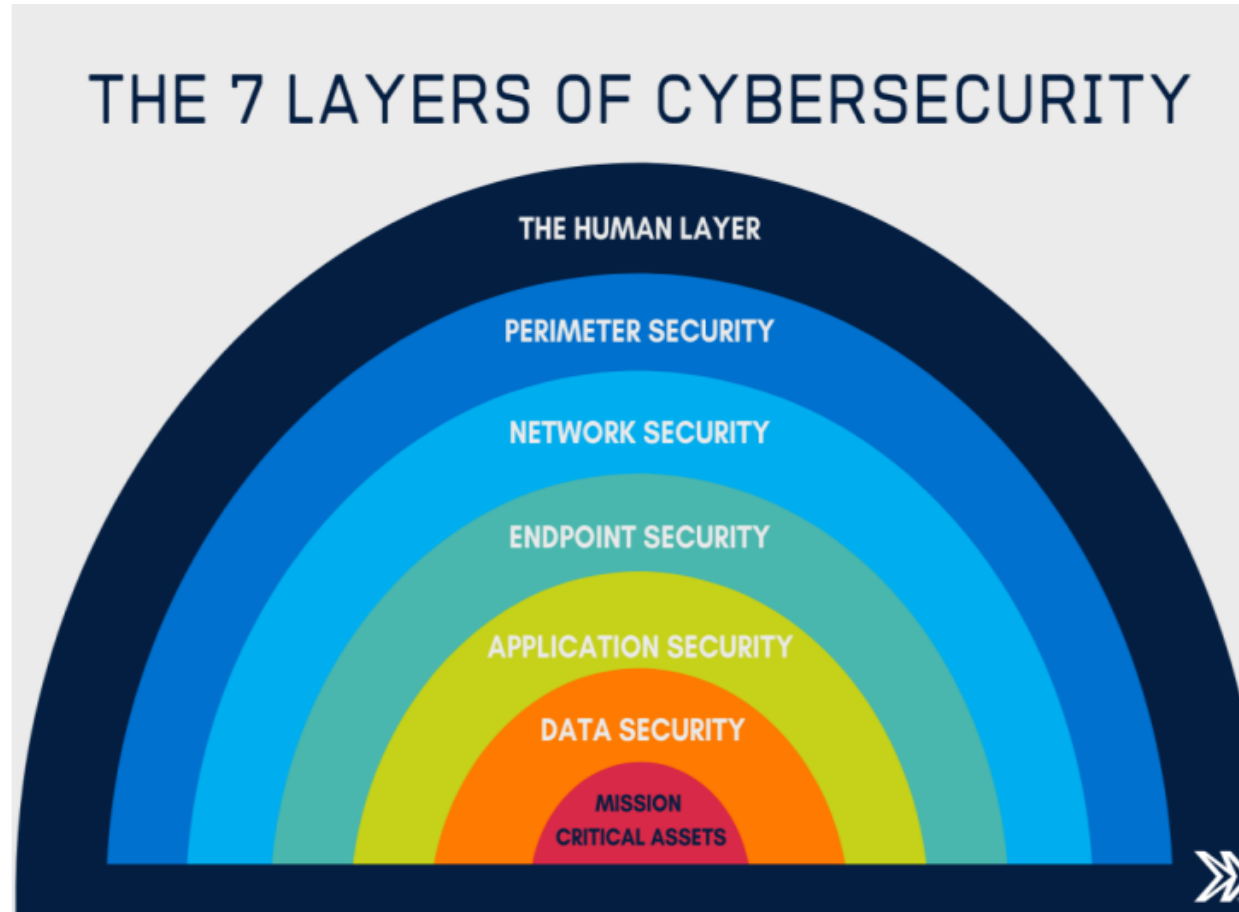
- **Backdoors**

- It is a method that bypasses the normal authentication process.
- A developer may create a backdoor so that an application or operating system can be accessed for troubleshooting or other purposes.

- **Bots**

- A bot (short for "robot") is an automated process that interacts with other network services.
- Some bots program run automatically, while others only execute commands when they receive specific input.
- Common examples of bots program are the crawler, chatroom bots, and malicious bots.

Layers of Cyber Security



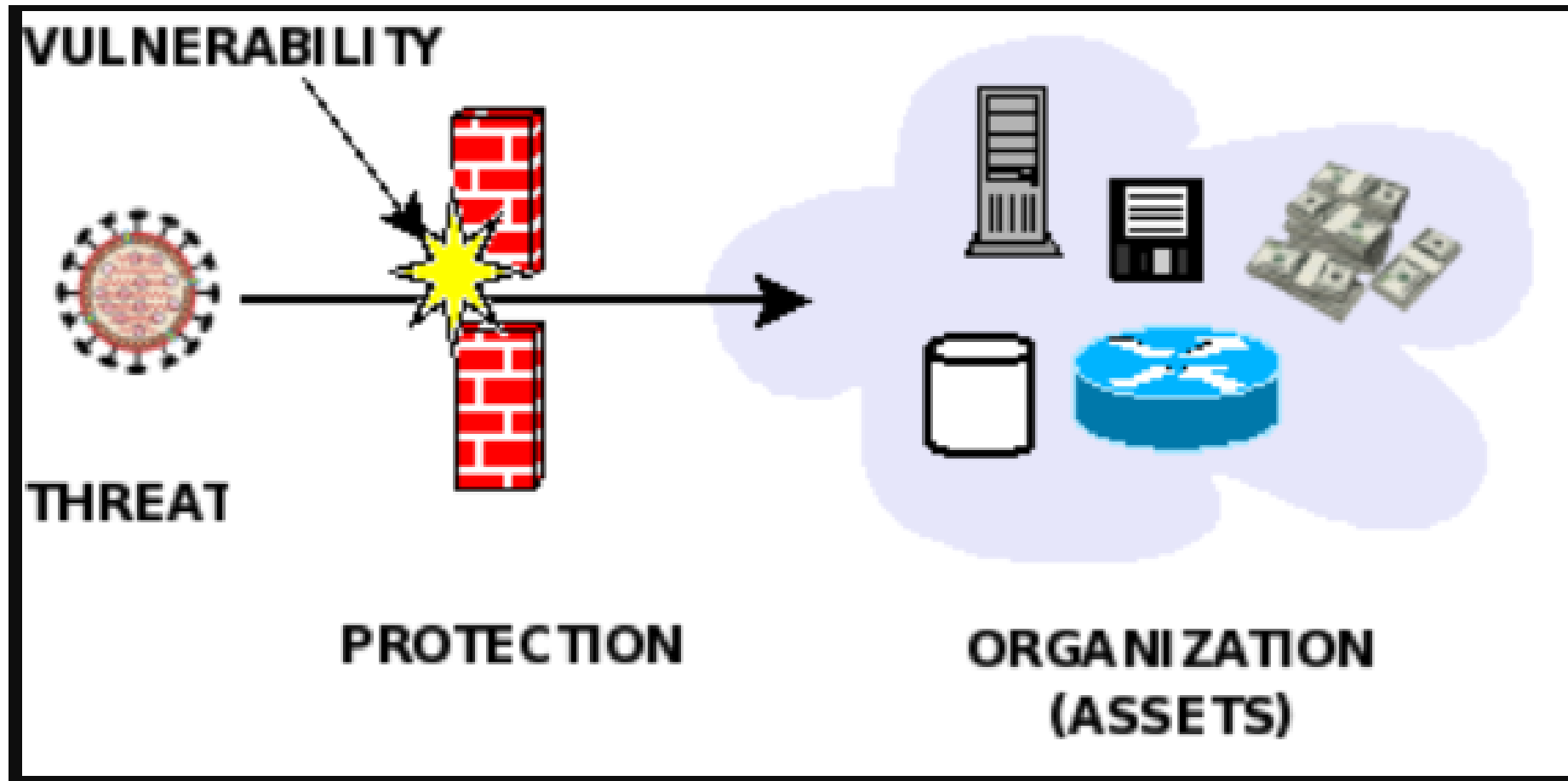
Layers of Cyber Security

- **Mission Critical Assets**
- This is the data you need to protect
- **Data Security**
- Data security controls protect the storage and transfer of data.
- **Application Security**
- Applications security controls protect access to an application, an application's access to your mission critical assets, and the internal security of the application.
- **Endpoint Security**
- Endpoint security controls protect the connection between devices and the network.

Layers of Cyber Security

- **Network Security**
- Network security controls protect an organization's network and prevent unauthorized access of the network.
- **Perimeter Security**
- Perimeter security controls include both the physical and digital security methodologies that protect the business overall.
- **The Human Layer**
- Humans are the weakest link in any cyber security posture.
- Human security controls include phishing simulations and access management controls that protect mission critical assets from a wide variety of human threats, including cyber criminals, malicious insiders, and negligent users.

Vulnerability, Threat, Assets



Vulnerability, Threat, Assets

- **Vulnerability, Threat, Assets**
- As the recent epidemic of data breaches illustrates, no system is immune to attacks.
- Any company that manages, transmits, stores, or otherwise handles data has to institute and enforce mechanisms to monitor their cyber environment, identify vulnerabilities, and close up security holes as quickly as possible.
- Before identifying specific dangers to modern data systems, it is crucial to understand the distinction between cyber threats and vulnerabilities.

Assets and Threat

- **Asset**
- An asset is any data, device or other component of an organization's systems that is valuable – often because it contains sensitive data or can be used to access such information.
- For example: An employee's desktop computer, laptop or company phone would be considered an asset, as would applications on those devices.
- Likewise, critical infrastructure, such as servers and support systems, are assets.
- An organization's most common assets are information assets.
- These are things such as databases and physical files – i.e. the sensitive data that you store

Assets and Threat

- **Threat**
- A threat is any incident that could negatively affect an asset – for example, if it's lost, knocked offline or accessed by an unauthorized party.
- Threats can be categorized as circumstances that compromise the confidentiality, integrity or availability of an asset, and can either be intentional or accidental.
- Intentional threats include things such as criminal hacking or a malicious insider stealing information, whereas accidental threats generally involve employee error, a technical malfunction or an event that causes physical damage, such as a fire or natural disaster.

Cyber Crime

- **Cyber Crime**
- Cybercrime is criminal activity that either targets or uses a computer, a computer network or a networked device.
- Cybercrime is committed by cybercriminals or hackers who want to make money.
- Cybercrime is carried out by individuals or organizations. Some cybercriminals are organized, use advanced techniques and are highly technically skilled.
- Others are novice hackers.

Cyber Crime

- **Cyber Terrorism**
- Cyber terrorism is the convergence of cyberspace and terrorism.
- It refers to unlawful attacks and threats of attacks against computers, networks and the information stored therein when done to intimidate or coerce a government or its people in furtherance of political or social objectives.
- Examples are hacking into computer systems, introducing viruses to vulnerable networks, web site defacing, Denial-of-service attacks, or terroristic threats made via electronic communication.

Cyber Terrorism



Cyber Crime

- **Cyber Espionage**
- Cyber spying, or cyber espionage, is the act or practice of obtaining secrets and information without the permission and knowledge of the holder of the information from individuals, competitors, rivals, groups, governments and enemies for personal, economic, political or military advantage using methods on the Internet.

Cyber Espionage



Best Practices for Cybersecurity

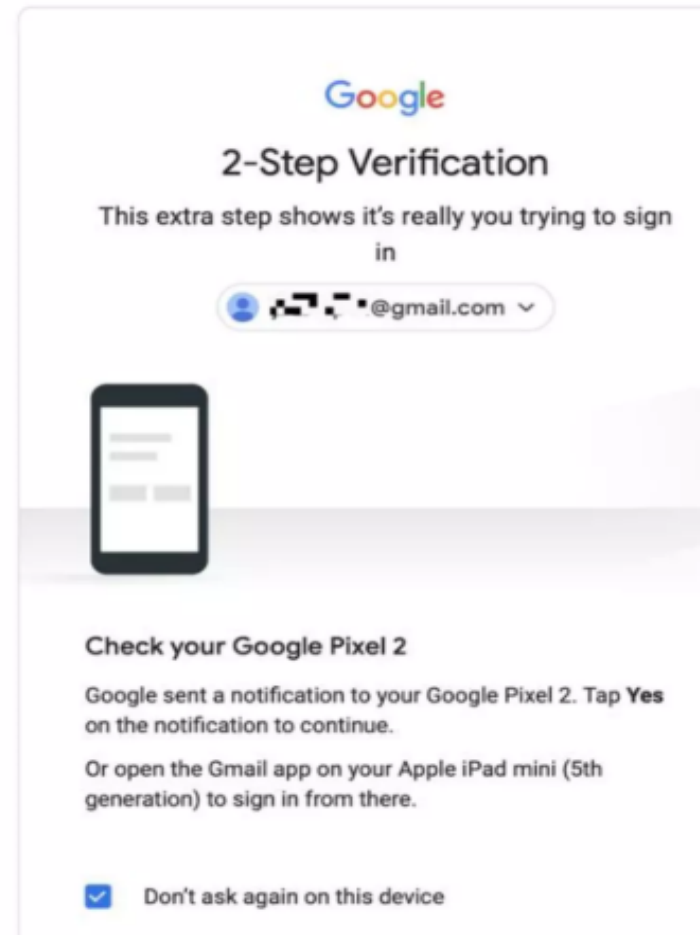
- Identity Protection
- Protect Username and Password
- Do not share personal information
- Secure online Transactions
- Avoid using Unsecure Wi-fi
- Don't Accept unknown invitation
- Use antivirus and anti spyware software
- Clear browser cookies frequently

PRECAUTIONS

- Install firewall- linux, window or Mac include firewall software
- Never install software from unknown sources
- Data stored in web browsers
- Password

Use two-factor or multi-factor authentication

Two factor or multi-factor authentication is a service that inserts additional layers of security such as **OTP**, **fingerprint**, etc other than the standard username and password method of online identification.



Secure Socket Layer(SSL)

- **Secure Socket Layer (SSL)**
- Secure Sockets Layer (SSL) is an Internet security protocol that encrypts data to ensure secure communication between devices over a network.
- Originally developed by Netscape in 1995, SSL provides privacy, authentication and data integrity for online communications.
- SSL is the predecessor of TLS (Transport Layer Security), which is now the standard protocol for secure communications on the Internet.

Secure Socket Layer(SSL)

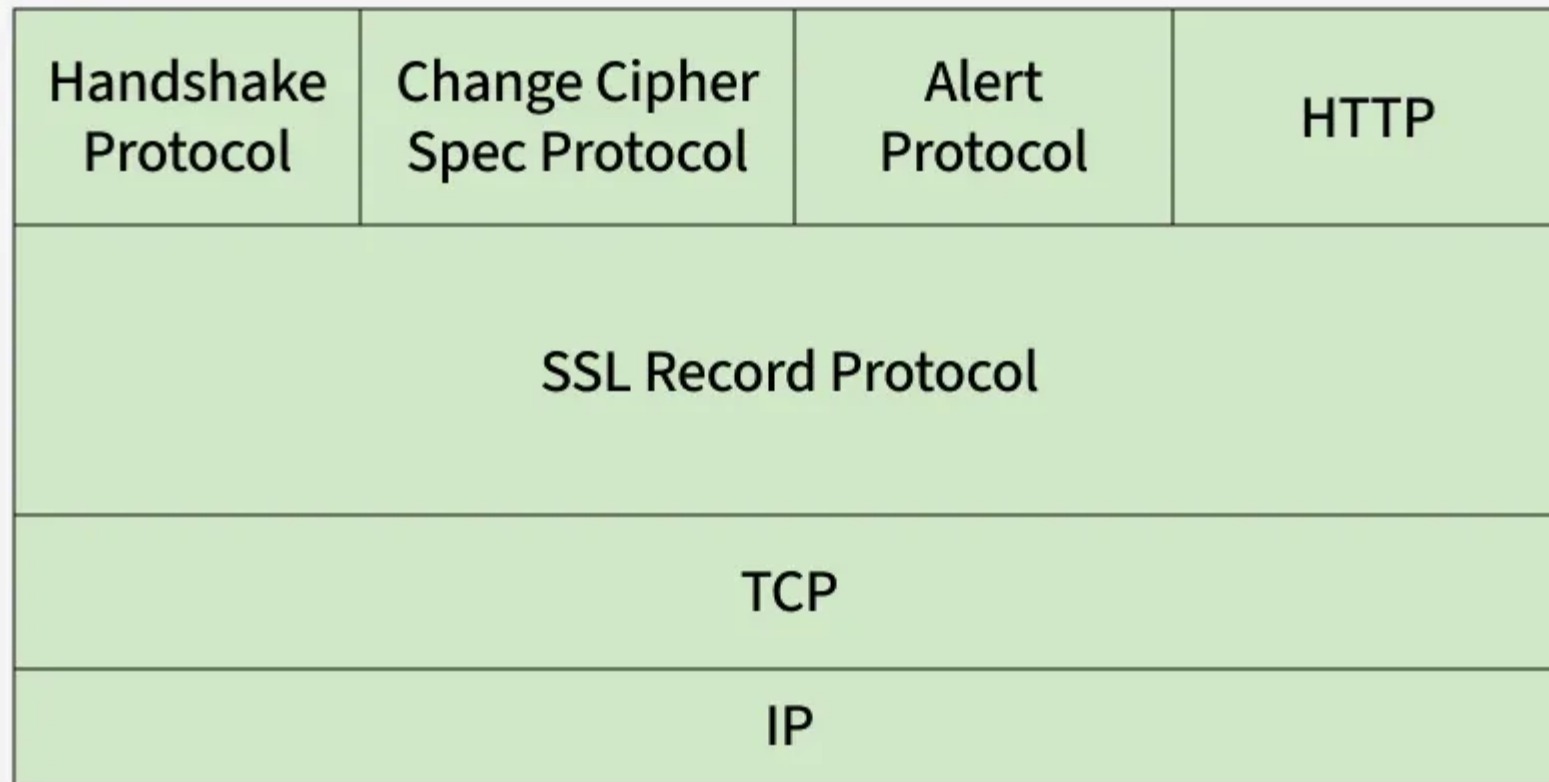


Fig : Secure Socket Layer

Secure Socket Layer(SSL)

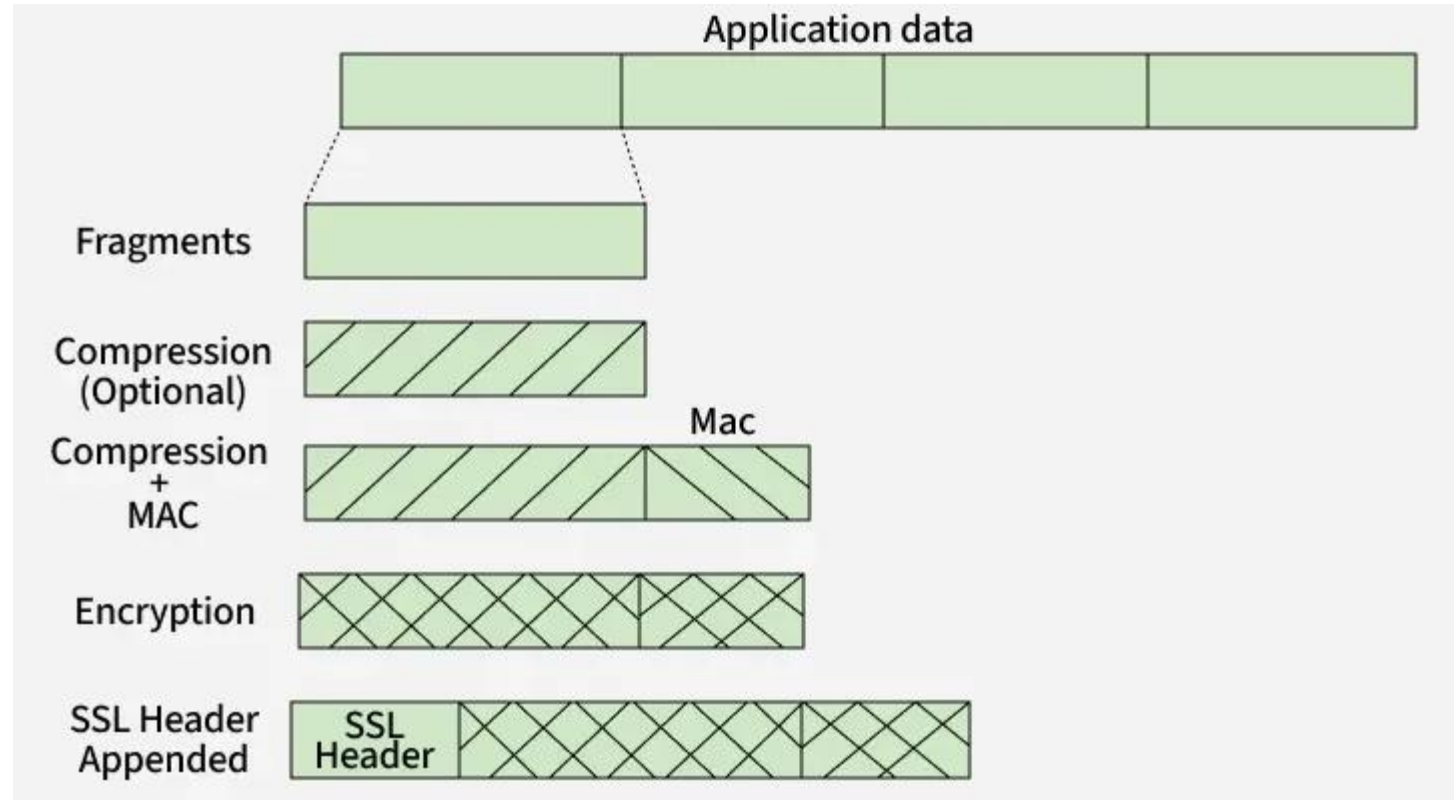
- **Working of SSL**
- SSL ensures secure communication through three main mechanisms:
- **Encryption:** Data transmitted over the network is encrypted, preventing unauthorized parties from reading it.
- If intercepted, encrypted data appears as an unreadable jumble of characters.
- **Authentication:** SSL uses a handshake process to authenticate both the client and server, ensuring each party is legitimate and not an imposter.
- **Data Integrity:** SSL digitally signs transmitted data to detect any tampering, ensuring that the data received is exactly what was sent.

Secure Socket Layer(SSL)

- **Importance of SSL**
- Before SSL, web data was transmitted in plaintext, making it vulnerable to interception. SSL solves this by:
- Encrypting sensitive information such as login credentials, financial transactions and personal data.
- Authenticating web servers to prevent users from connecting to fraudulent websites.
- Ensuring data integrity so transmitted information cannot be modified during transit.

Secure Socket Layer(SSL)

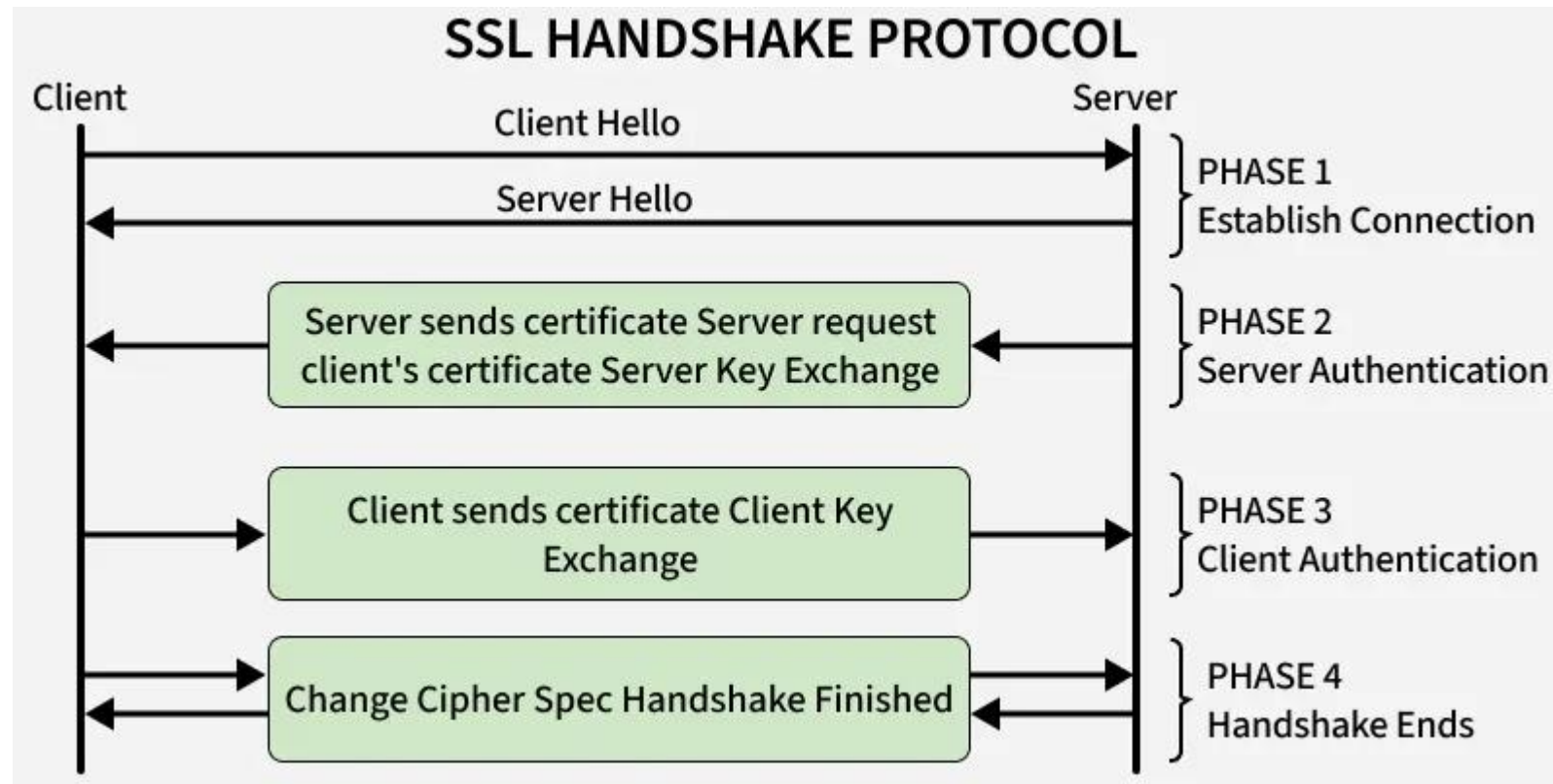
- **SSL Record Protocol**



- Provides confidentiality and message integrity.
- Application data is divided into fragments, optionally compressed and appended with a Message Authentication Code (MAC).
- The data is then encrypted and transmitted with an SSL header.

Secure Socket Layer(SSL)

- **Handshake Protocol**



Secure Socket Layer(SSL)

- Establishes SSL sessions and authenticates clients and servers.
- **Four phases:**
- Client and server exchange hello packets, protocol versions and cipher suites.
- Server sends its certificate and server key information.
- Client responds with its certificate and key exchange.
- Change Cipher Spec finalizes the handshake, activating secure communication.

Secure Socket Layer(SSL)

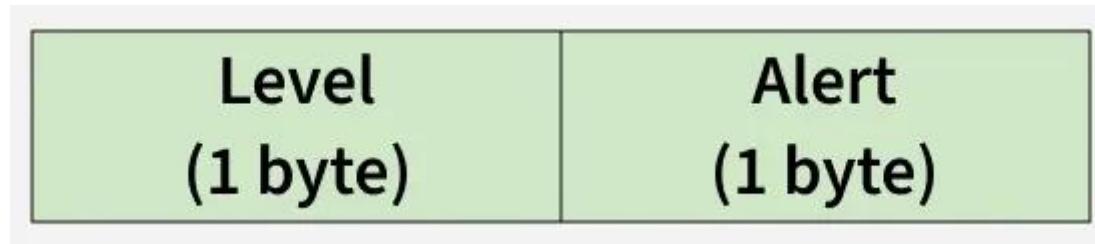
- **Change-Cipher Spec Protocol**



- Signals that pending cryptographic parameters from the handshake should now become active.
- Consists of a single 1-byte message.

Secure Socket Layer(SSL)

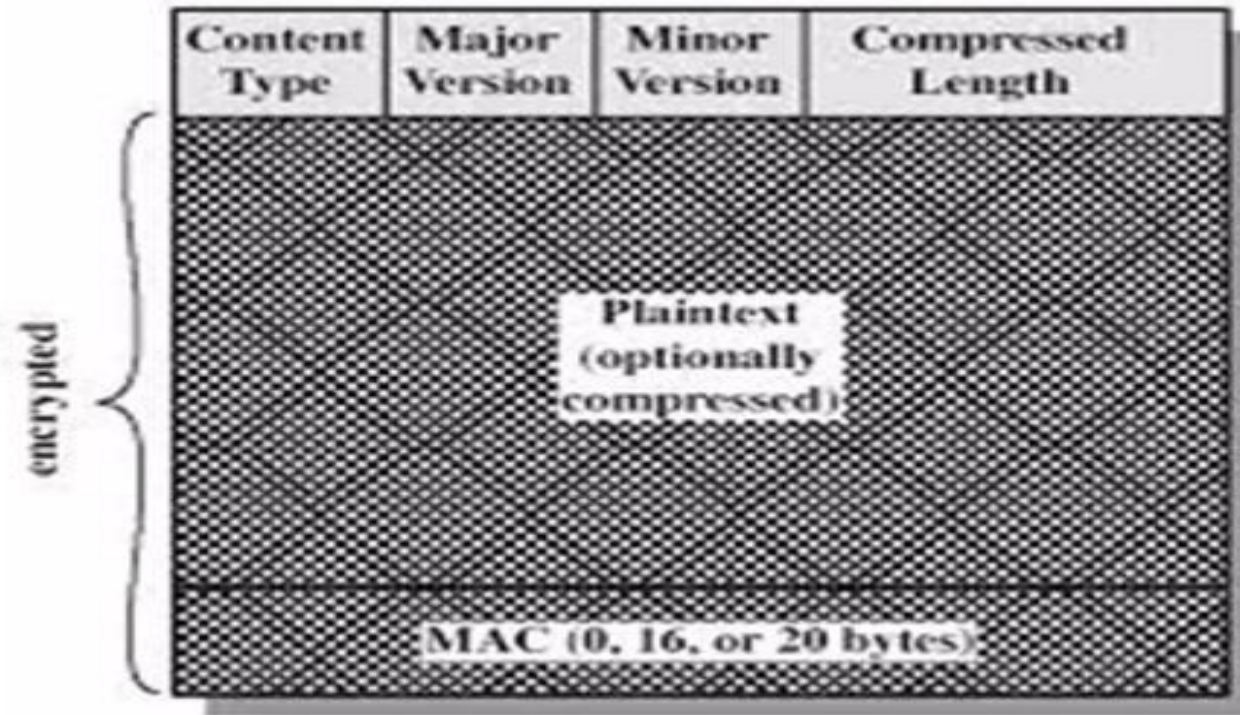
- **Alert Protocol**



- Communicates SSL-related warnings or errors.
- **Warning alerts (level 1):** Non-critical issues, such as expired or unsupported certificates.
- **Fatal alerts (level 2):** Critical errors, such as handshake failures, bad record MAC or illegal parameters, which terminate the connection.

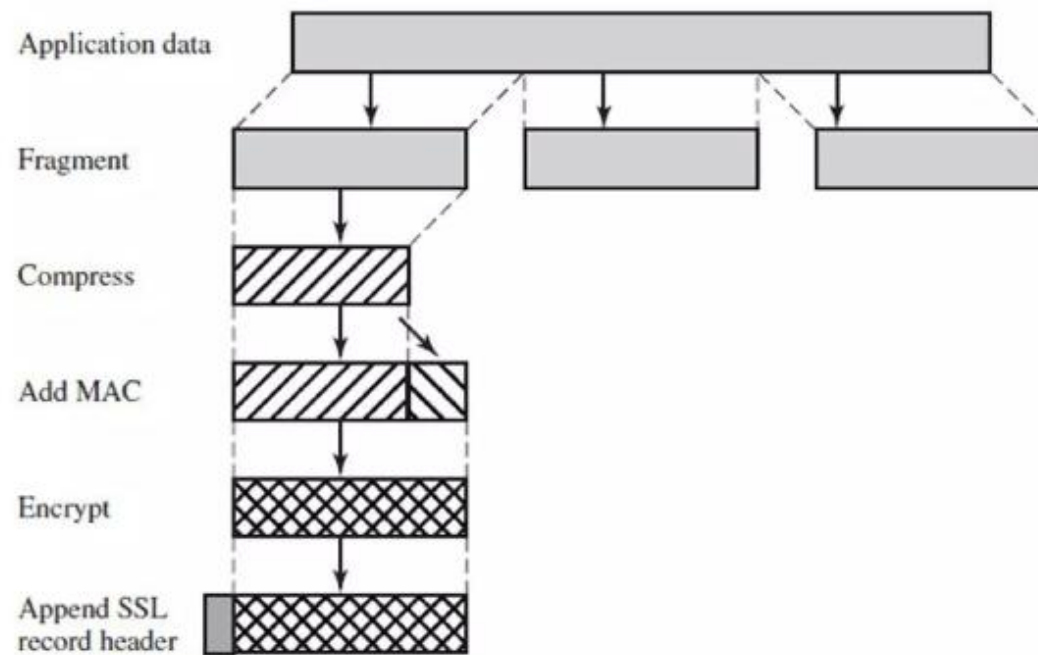
Secure Socket Layer(SSL)

- **SSL Record Protocol Format**



Secure Socket Layer(SSL)

SSL Record Protocol - Operation



Secure Socket Layer(SSL)

SSL Record Protocol

1. Content type: It specifies which protocol is used for processing.
2. Major version: It specifies the major version of SSL used, for example if SSL version 3.1 is in use than this field contains 3.
3. Minor version: It specifies minor version of SSL used, for example version 3.0 is in use than field contains 0.
4. Compressed length: It specifies the length in bytes of the original plain text block.

Secure Socket Layer(SSL)

SSL Alert Protocol

- The Alert Protocol is used to convey SSL-related alerts to the peer entity. As with other applications that use SSL, alert messages are compressed and encrypted, as specified by the current state.
- The first byte takes the value warning (1) or fatal (2) to convey the severity of the message. If the level is fatal, SSL immediately terminates the connection.
- Other connections on the same session may continue, but no new connections on this session may be established.
- The second byte contains a code that indicates the specific alert.

Secure Socket Layer(SSL)

SSL Alert Protocol

- Fatal alerts:
- Unexpected message: It raised when inappropriate messages are received.
- Bad record MAC: It raised when message received with incorrect MAC.
- Handshake failure: It raised when the sender is unable to negotiate an acceptable set of security parameters from options.
- Decompression Failure: It raised when decompression function cannot be completed.
- Illegal parameters: It raised when the field in Handshake message is out of range.

Secure Socket Layer(SSL)

SSL Alert Protocol

- Non-fatal alerts:
- Certificate expired: It raised when certificate expired.
- Certificate revoked: It raised when signer of certificate invoked it.
- Certificate unknown: It raised when an unspecified error occurred while processing certificate.
- Bad certificate: It raised when a certificate is corrupted.
- Unsupported certificate: It raised when Certificate types do not support.
- Close notify: This alert notifies that sender will not send any more messages in this connection.
- No certificate: It raised when appropriate certificate is not available.

Transport layer Security(TLS)

What is Transport Layer Security (TLS)

- TLS is the successor to the Secure Sockets Layer ([SSL](#)).
- Transport Layer Security (**TLS**) is a protocol that ensures privacy between communicating applications and their users on the Internet.

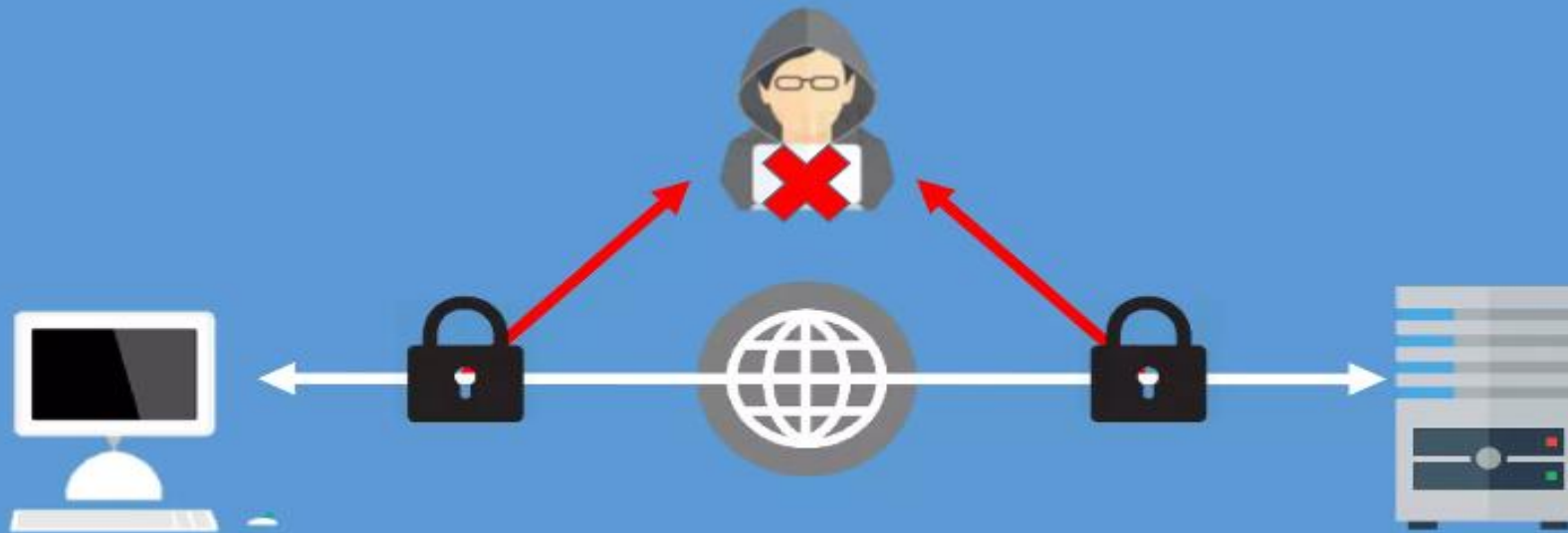
-Techtarget.com



Transport layer Security(TLS)

Why do we need it?

- TLS ensures that no third party may eavesdrop or tamper with any message.



Transport layer Security(TLS)

Benefits of TLS



Encryption



Algorithm
flexibility



Interoperability



Ease of
deployment

Transport layer Security(TLS)

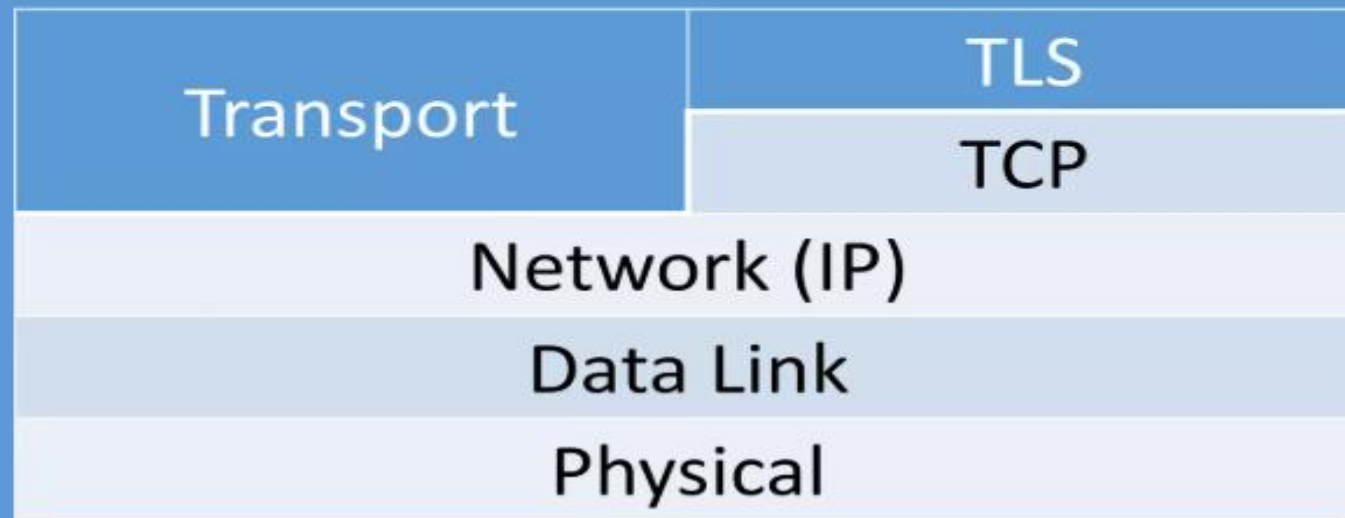
Benefits of TLS

- Encryption
 - TLS/SSL can help to secure transmitted data using encryption.
- Interoperability
 - TLS/SSL works with most Web browsers, including Microsoft Internet Explorer and Netscape Navigator, and on most operating systems and Web servers.
- Algorithm flexibility
 - TLS/SSL provides options for the authentication mechanisms, encryption algorithms, and hashing algorithms that are used during the secure session.
- Ease of deployment
 - Many applications use TLS/SSL transparently on a Windows Server 2003 operating systems.
- Ease of use
 - Because you implement TLS/SSL beneath the application layer, most of its operations are completely invisible to the client.

Transport layer Security(TLS)

Transport Layer Security (Basics)

- SSL & [TLS](#) are protocols that operates directly on top of TCP



Transport layer Security(TLS)

Working of Transport Layer Security

- The Client connect to server (using TCP). The client can be anything.
- The Client sends a number of specifications :
 - Version of SSL/TLS
 - Which cipher suites, compression method it wants to use.



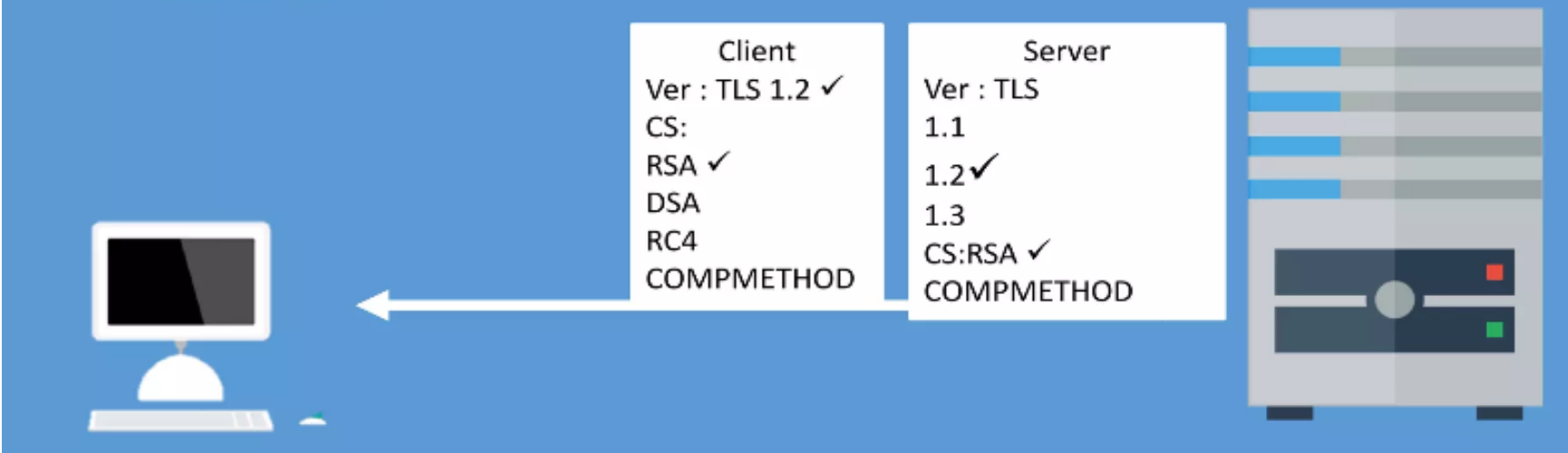
Ver : TLS 1.2
CS:RSA,DSA,RC4
COMPMETHOD



Transport layer Security(TLS)

Working of Transport Layer Security

- The server checks what the highest SSL/TLS version is that is supported by them both, picks a ciphersuite from one of the client's options (if it supports one), and optionally picks a compression method.



Transport layer Security(TLS)

Working of Transport Layer Security

- After this the basic setup is done, the server sends its certificate.
- This certificate must be trusted by either the client itself or a party that the client trusts.
- For example if the client trusts GeoTrust, then the client can trust the certificate from Google.com, because GeoTrust cryptographically signed Google's certificate.



Transport layer Security(TLS)

Working of Transport Layer Security

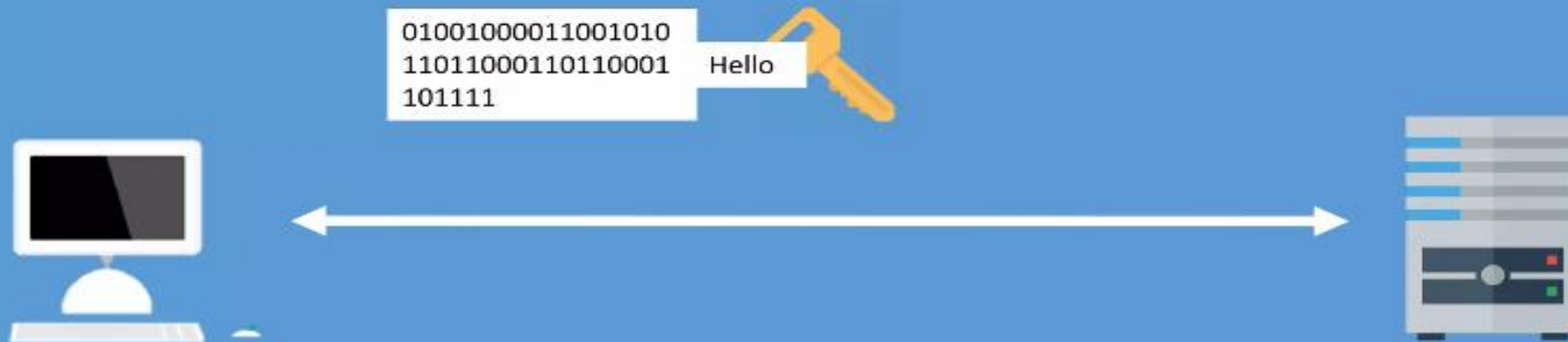
- Having verified the certificate and being certain this server really is who he claims to be (and not a man in the middle), a key is exchanged.
- This can be a public key, a "PreMasterSecret" or simply nothing, depending on the chosen ciphersuite.



Transport layer Security(TLS)

Working of Transport Layer Security

- Both the server and the client can now compute the key for the [symmetric encryption](#).



Transport layer Security(TLS)

Working of Transport Layer Security

- The handshake is now finished, and the two hosts can communicate securely.



Transport layer Security(TLS)

Working of Transport Layer Security

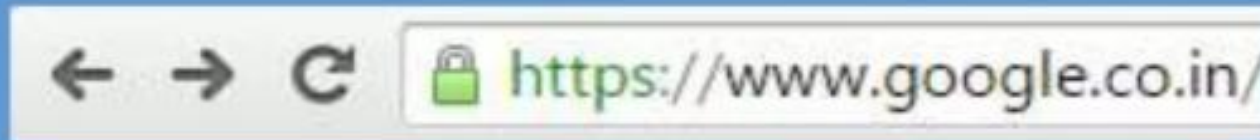
- To close the connection, a close_notify 'alert' is used. If an attacker tries to terminate the connection by finishing the TCP connection (injecting a FIN packet), both sides will know the connection was improperly terminated. The connection cannot be compromised by this though, merely interrupted



Transport layer Security(TLS)

How to detect secure connections

- Chrome can display the version. Click on the padlock icon (on the left of the URL); a popup appears, which contains some details, including the protocol version (e.g. "the connection uses TLS 1.0")(verified on version 21.0.1180.82).



Transport layer Security(TLS)

Examples

The image displays four browser security status panels, each showing the connection details for a specific website. The panels are arranged horizontally. Each panel has a title bar with the website's URL and a close button. Below the title bar, there are tabs for 'Permissions' and 'Connection'. The 'Connection' tab is selected in all panels. The panels show the following information:

- mail.google.com:** Identity verified. The identity of this website has been verified by Google Internet Authority G2 but it does not have public audit records. Your connection to mail.google.com is encrypted with modern cryptography. The connection uses QUIC. The connection is encrypted and authenticated using AES_128_GCM and uses ECDHE_RSA as the key exchange mechanism. Site information: You first visited this site on 14 Feb 2015.
- mumbai.police.maharashtra.gov.in:** Identity verified. The identity of this website has been verified by Thawte SSL CA but it does not have public audit records. Your connection to mumbai.police.maharashtra.gov.in is encrypted with obsolete cryptography. However, this page includes other resources which are not secure. These resources can be viewed by others while in transit and can be modified by an attacker to change the look of the page. The connection uses TLS 1.0. The connection is encrypted using AES_128_CBC, with SHA1 for message authentication and RSA as the key exchange mechanism. Site information: You have never visited this site before today.
- www.maharashtra.gov.in:** Identity verified. The identity of this website has been verified by Thawte SSL CA but it does not have public audit records. Your connection to www.maharashtra.gov.in is encrypted with obsolete cryptography. The connection uses TLS 1.0. The connection is encrypted using AES_256_CBC, with SHA1 for message authentication and ECDHE_RSA as the key exchange mechanism. Site information: You have never visited this site before today.
- www.pewdiepie.com:** Identity not verified. The identity of this website has not been verified. Your connection to www.pewdiepie.com is not encrypted. Site information: You have never visited this site before today.

Each panel also includes a link to 'What do these mean?' for more information.

IP Security(IPSec)

- **What is IP Security (IPSec)**
- IP Security (IPSec) refers to a collection of communication rules or protocols used to establish secure network connections.
- Internet Protocol (IP) is the common standard that controls how data is transmitted across the internet.
- IPSec enhances the protocol security by introducing **encryption** and **authentication**.
- IPSec encrypts data at the source and then decrypts it at the destination.
- It also verifies the source of the data.

IP Security(IPSec)

- **Importance of IPSec**
- **IPSec (Internet Protocol Security)** is important because it helps keep your data safe and secure when you send it over the Internet or any network. Here are some of the important aspects why IPSec is Important:
- IPSec protects the data through Data Encryption.
- IPSec provides Data Integrity.
- IPSec is often used in Virtual Private Networks (VPNs) to create secure, private connections.
- IPSec protects from Cyber Attacks.

IP Security(IPSec)

- **Features of IPSec**
- **Authentication:** IPSec provides authentication of IP packets using digital signatures or shared secrets. This helps ensure that the packets are not tampered with or forged.
- **Confidentiality:** IPSec provides confidentiality by encrypting IP packets, preventing eavesdropping on the network traffic.
- **Integrity:** IPSec provides integrity by ensuring that IP packets have not been modified or corrupted during transmission.
- **Key management:** IPSec provides key management services, including key exchange and key revocation, to ensure that cryptographic keys are securely managed.

IP Security(IPSec)

- **Tunneling:** IPSec supports tunneling, allowing IP packets to be encapsulated within another protocol, such as GRE (Generic Routing Encapsulation) or L2TP (Layer 2 Tunneling Protocol)].
- **Flexibility:** IPSec can be configured to provide security for a wide range of network topologies, including point-to-point, site-to-site, and remote access connections.
- **Interoperability:** IPSec is an open standard protocol, which means that it is supported by a wide range of vendors and can be used in heterogeneous environments.

IP Security(IPSec)

- **IP Security Architecture**
- IPSec (IP Security) architecture uses two protocols to secure the traffic or data flow. These protocols are
- ESP (Encapsulation Security Payload)
- AH (Authentication Header)
- IPSec Architecture includes protocols, algorithms, DOI, and Key Management.
- All these components are very important in order to provide the three main services such as Confidentiality, Authenticity and Integrity.

IP Security(IPSec)

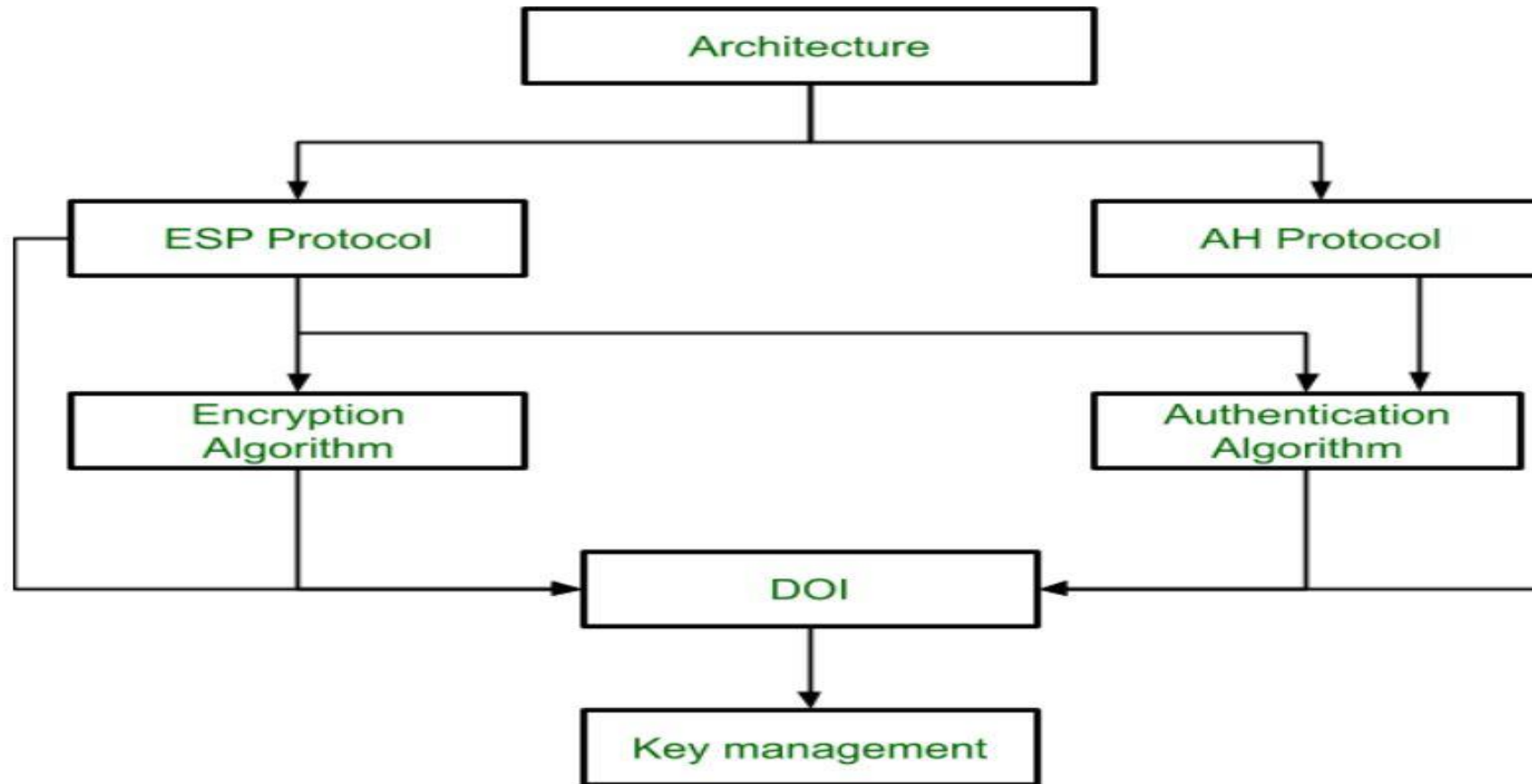
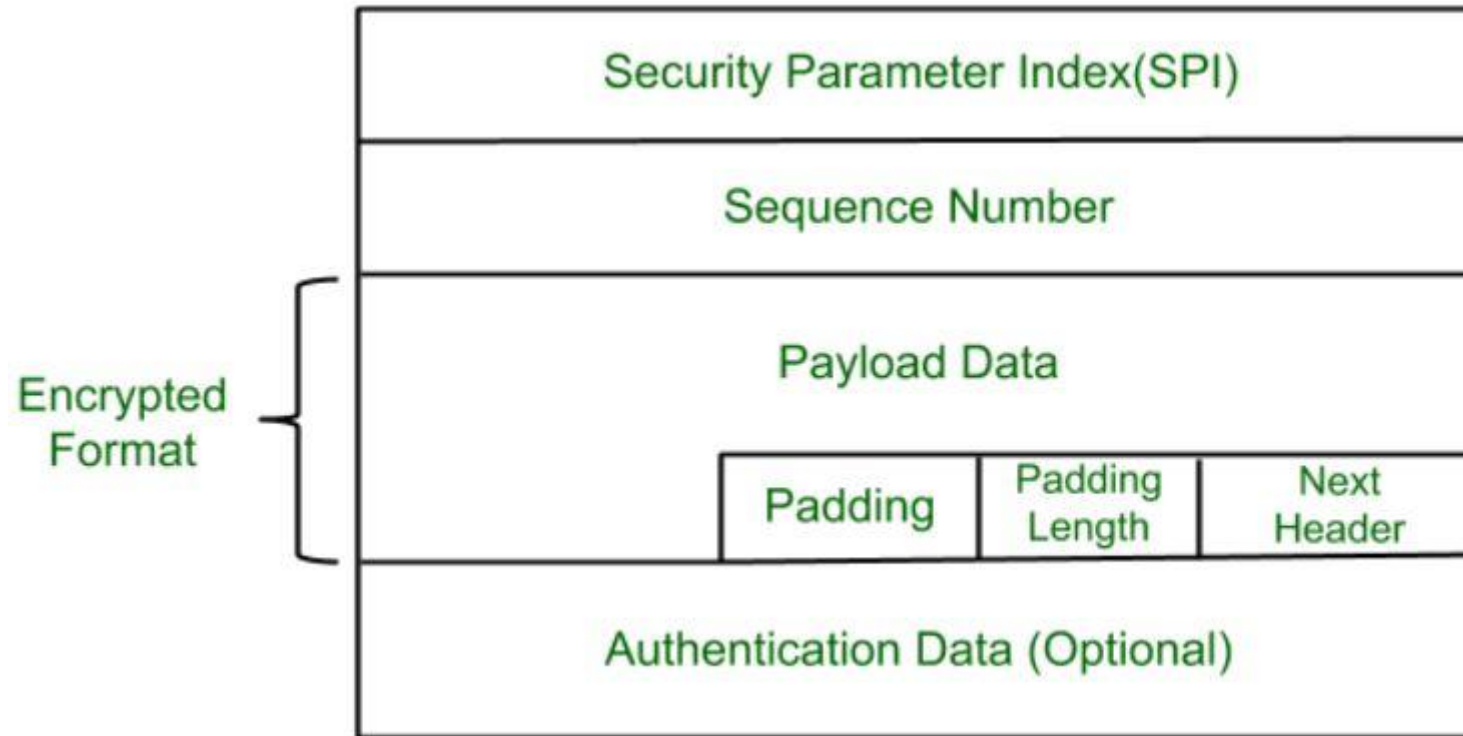


Fig: IPsec Architecture

IP Security(IPSec)

- **1. Architecture:** Architecture or IP Security Architecture covers the general concepts, definitions, protocols, algorithms, and security requirements of IP Security technology.
- **2. ESP Protocol:** ESP(Encapsulation Security Payload) provides a confidentiality service.
- Encapsulation Security Payload is implemented in either two ways:
 - ESP with optional Authentication.
 - ESP with Authentication.

IP Security(IPSec)



IP Security(IPSec)

- **Security Parameter Index(SPI):** This parameter is used by Security Association. It is used to give a unique number to the connection built between the Client and Server.
- **Sequence Number:** Unique Sequence numbers are allotted to every packet so that on the receiver side packets can be arranged properly.
- **Payload Data:** Payload data means the actual data or the actual message. The Payload data is in an encrypted format to achieve confidentiality.
- **Padding:** Extra bits of space are added to the original message in order to ensure confidentiality. Padding length is the size of the added bits of space in the original message.
- **Next Header:** Next header means the next payload or next actual data.
- **Authentication Data** This field is optional in ESP protocol packet format.

IP Security(IPSec)

- **3. Encryption algorithm:** The encryption algorithm is the document that describes various encryption algorithms used for Encapsulation Security Payload.
- **4. AH Protocol:** AH (Authentication Header) Protocol provides both Authentication and Integrity service.
- Authentication Header is implemented in one way only: Authentication along with Integrity.
- Authentication Header covers the packet format and general issues related to the use of AH for packet authentication and integrity.

IP Security(IPSec)

Next Header	Payload Length	Reserved
Security Parameter Index		
Sequence Number		
Authentication Data (Integrity Checksum)		

Fig: Authentication Header

IP Security(IPSec)

- **5. Authentication Algorithm:** The authentication Algorithm contains the set of documents that describe the authentication algorithm used for AH and for the authentication option of ESP.
- **6. DOI (Domain of Interpretation):** DOI is the identifier that supports both AH and ESP protocols.
 - It contains values needed for documentation related to each other.
- **7. Key Management:** Key Management contains the document that describes how the keys are exchanged between sender and receiver.

IP Security(IPSec)

- **Protocols Used in IPSec**
- It has the following components:
- Encapsulating Security Payload (ESP)
- Authentication Header (AH)
- Internet Key Exchange (IKE)
- **1. Encapsulating Security Payload (ESP):** It provides data integrity, encryption, authentication, and anti-replay. It also provides authentication for payload.
- **2. Authentication Header (AH):** It also provides data integrity, authentication, and anti-replay and it does not provide encryption.
- The anti-replay protection protects against the unauthorized transmission of packets. It does not protect data confidentiality.

IP Security(IPSec)

- **3. Internet Key Exchange (IKE):** It is a network security protocol designed to dynamically exchange encryption keys and find a way over Security Association (SA) between 2 devices.
- The Security Association (SA) establishes shared security attributes between 2 network entities to support secure communication.
- The Key Management Protocol (ISAKMP) and Internet Security Association provides a framework for authentication and key exchange.
- ISAKMP tells how the setup of the Security Associations (SAs) and how direct connections between two hosts are using IPsec. Internet Key Exchange (IKE) provides message content protection and also an open frame for implementing standard algorithms such as SHA and MD5.
- The algorithm's IP sec users produce a unique identifier for each packet.
- This identifier then allows a device to determine whether a packet has been correct or not. Packets that are not authorized are discarded and not given to the receiver.

IP Security(IPSec)

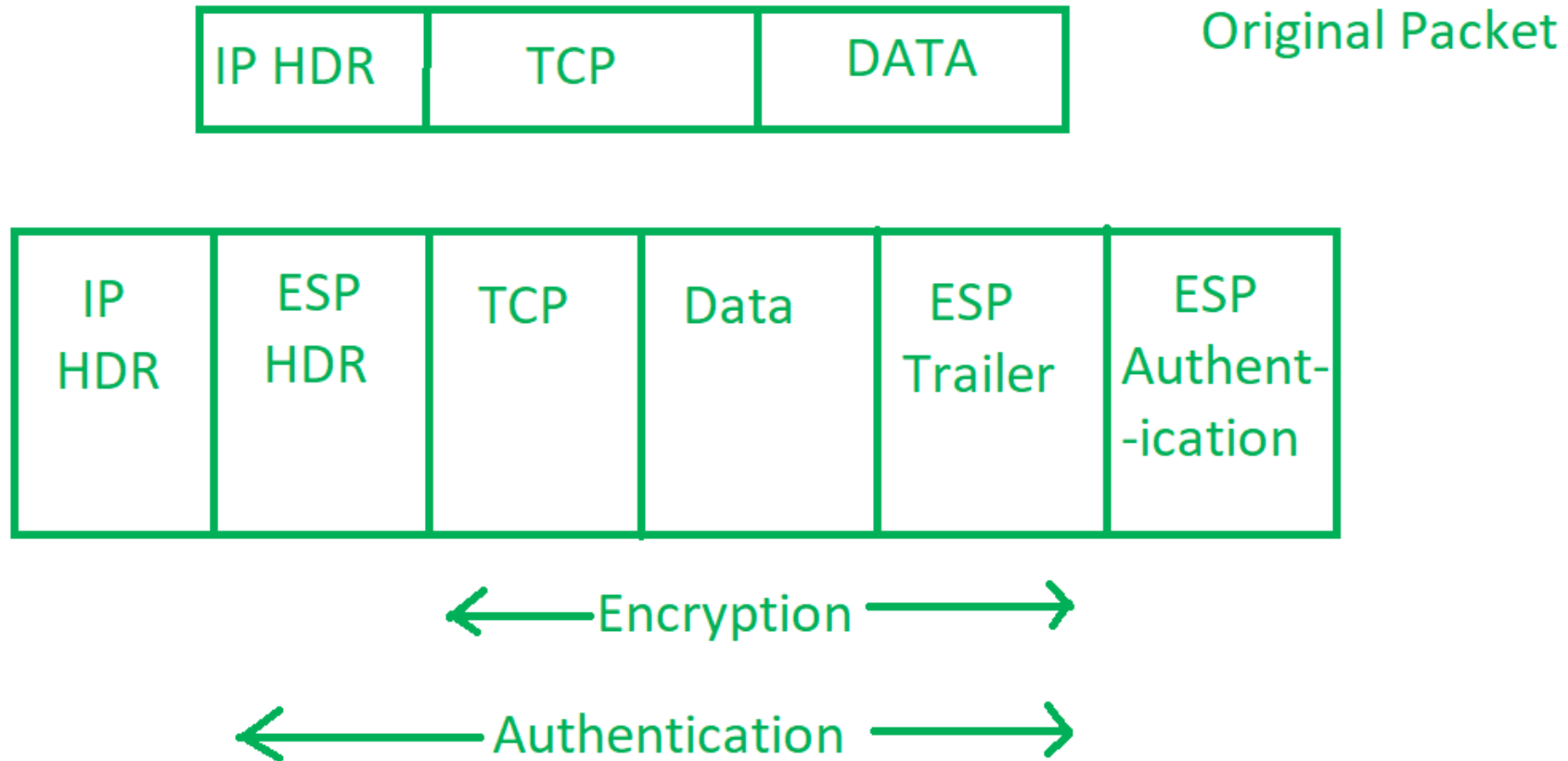
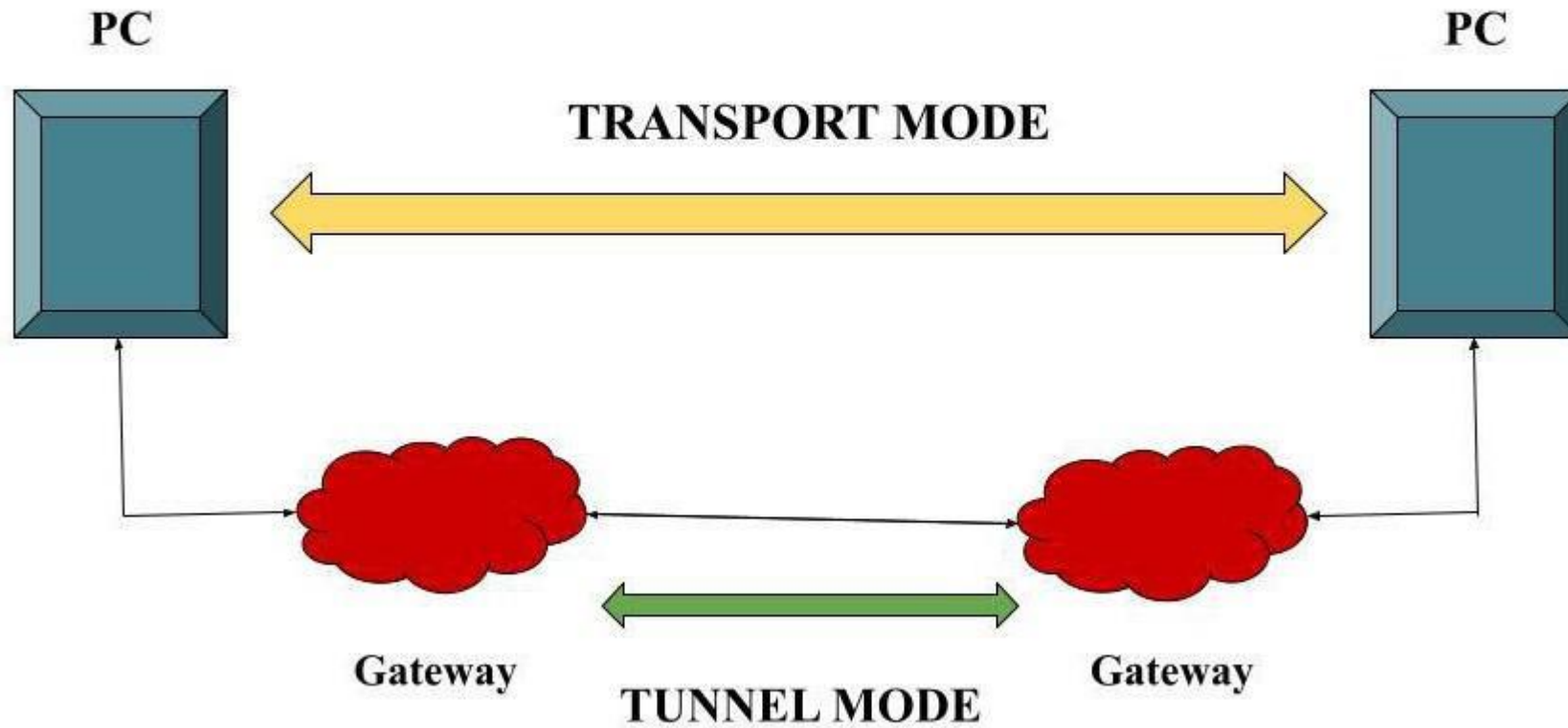


Fig: Packets in Internet Protocol

IP Security(IPSec)

IPSec Modes



IP Security(IPSec)

- **IPsec Tunnel Mode**
- **Full Header and Payload Encryption:** In Tunnel Mode, the complete original IP packet (header and payload) is encrypted after which it is encapsulated inside a new IP packet.
- This new packet has a different IP header, normally with exclusive source and destination spotted on its IP addresses.
- **Used for Site-to-Site VPNs:** Tunnel Mode is normally utilized in site-to-web page VPNs (Virtual Private Networks) in which entire networks or subnets need to talk securely over an untrusted network, including the Internet.
- **Protects Network-to-Network Communication:** Network to network Communication secures communication between all the networks, for encryption and protection from attacks.

IP Security(IPSec)

- **Explanation**
- **Use Case**
- Tunnel Mode is frequently used in website-to-web site VPNs, in which complete networks or subnets need secure communication.
- It protects the entire conversation between two networks.
- **Example:**
- Consider branch places of work of an organization.
- They join over the internet the usage of Tunnel Mode to safely exchange sensitive information.
- The authentic IP packets are encapsulated within new IP packets with extraordinary source and destination addresses.

IP Security(IPSec)

- **IPsec Transport Mode**
- **Payload encryption simplest:** In shipping mode, preferably the payload (information) of a valid IP packet is encrypted, while the valid IP header stays intact.
- This mode is usually used to pause communication between hosts or gadgets.
- **Used for host-to-host communication:** The host-to-host communication mode is generally used to guard communication among hosts or devices in preference to the whole network.
- **Less overhead:** Since the original IP header no longer trades, new headers may have less overhead in keeping with the sentence compared to Tunnel Mode.

IP Security(IPSec)

- **Explanation**
- **Use Case**
- Transport mode is suitable for drop-off connections among hosts or devices in the location.
- **Example:**
- Transport mode is used when employees in an employer need to soundly trade their documents locally.
- Only the payload of a valid IP packet is encrypted, at the same time as the IP header no longer alternates.

IP Security(IPSec)

- **How Does IPSec Work**
- IPSec (Internet Protocol Security) is used to secure data when it travels over the Internet.
- IPSec works by creating secure connections between devices, making sure that the information exchanged is kept safe from unauthorized access. IPSec majorly operates in two ways i.e. **Transport Mode** and **Tunnel Mode**.
- To provide security, IPSec uses two main protocols: **AH (Authentication Header)** and **ESP (Encapsulating Security Payload)**.
- Both protocols are very useful as **Authentication Header** verifies the data that whether it comes from a trusted source and hasn't been changed, and **ESP** has the work of performing authentication and also encrypts the data so that it becomes difficult to read.

IP Security(IPSec)

- For Encryption, IPSec uses cryptographic keys.
- It can be created and shared using a process called **IKE (Internet Key Exchange)**, that ensures that both devices have the correct keys to establish a secure connection.
- When two devices communicate using IPSec, the devices first initiate the connection by sending a request to each other.
- After that, they mutually decide on protection of data using **passwords** or **digital certificates**.
- Now, they establish the secure tunnel for communication. Once the tunnel is set up, data can be transmitted safely, as IPSec is encrypting the data and also checking the integrity of the data to ensure that data has not been altered.
- After the communication is finished, the devices can close the secure connection. In this way, the IPSec works.

IP Security(IPSec)

- **IPSec Connection Establishment Process**
- **Phase 1: Establishing the IKE (Internet Key Exchange) Tunnel**
- In phase 1, the main aim is to establish the secure channel the IKE tunnel, which is used to further negotiations.
- Phase 1 can operate in one of two modes:
- **Main Mode:** Main Mode is a six-message exchange procedure that is more secure than Basic Mode, although at the cost of a longer session, since identity information is transmitted during negotiations.
- **Aggressive Mode:** Aggressive Mode takes lesser time with the exchange of three messages and is less secure since more information like identity is disclosed during the course of negotiation.

IP Security(IPSec)

- **Phase 2: Establishing the IPSec Tunnel**
- Phase 2 is called Quick Mode and its aim is to negotiate the IPSec Security Associations after the construction of a secure IKE tunnel has been made.
- There are two modes in Phase 2.
- **Tunnel Mode:** This mode encapsulates the whole of the original IP packet including the header and data.
- It is mostly deployed in the site to site VPNs.
- **Transport Mode:** By this mode, only the actual data to be transmitted is encrypted and the header part of the IP packets remain unaltered.
- It is mainly employed in end to end communication between hosts.

IP Security(IPSec)

- **Difference Between IPSec Tunnel Mode and IPSec Transport Mode**
- The IPSec tunnel mode is appropriate for sending data over public networks because it improves data security against unauthorized parties.
- The computer encrypts all data, including the payload and header, and adds a new header to it.
- IPSec transport mode encrypts only the data packet's payload while leaving the IP header unchanged.
- The unencrypted packet header enables routers to determine the destination address of each data packet.
- As a result, IPSec transport is utilized in a closed and trusted network, such as to secure a direct link between two computers.

Email Security

- Your email is like a busy mailbox, full of messages like letters, photos, or important files.
- But sneaky hackers are out there, trying to steal your stuff or trick you.
- Email security is like a superhero that protects your inbox from bad guys.
- Email security protects your messages and data from unauthorized access, phishing, spam, and malware.
- It keeps your emails private, accurate, and safe using tools like encryption and spam filters.
- It protects against threats like phishing, spam, and malware using tools like encryption, spam filters, and two-factor authentication (2FA).
- By combining tech solutions and smart habits, you can ensure your emails stay secure.

Email Security

- **Why is email security important?**
- Emails are like a playground for hackers. Here's why you need to protect your inbox:
- **Hackers Love Emails: 94% of viruses** come through emails, and fake emails can trick you into giving away your password.
- **Big Problems:** If hackers get in, they can steal your info, mess up your work, or make you look bad.
- **Follow the Rules:** Laws like **GDPR(General Data Protection regulation)** and **HIPAA(Health Insurance Portability and Accountability Act)** say you have to keep emails safe, or you could get in trouble.
- **Stay Focused:** A safe inbox means less spam and fewer problems, so you can focus on fun stuff like work or sharing pet pics.

Email Security

- **Benefits of Email Security**
- Email security isn't just about avoiding digital bullets; it's about peace of mind. Here's what you gain:
- **Stop Fake Emails:** Tools catch tricky emails that pretend to be from your friend or bank.
- **Lock Your Info:** Encryption keeps private stuff—like bank details or secret plans—safe from snoopers.
- **Private Messages:** Only the person you send to can read your email, like a sealed letter.
- **No Junk:** Smart filters delete spam and bad emails, keeping your inbox tidy.
- **Fast Protection:** New tech spots dangers right away, stopping hackers before they start.
- **Keep Your Account Safe:** Encryption and 2FA stop hackers from taking over your email or stealing your info

Email Security

- **PGP - Authentication and Confidentiality**
- Pretty Good Privacy (PGP) is an encryption software designed to ensure the confidentiality, integrity, and authenticity of virtual communications and information.
- It is considered as one of the best methods for securing digital facts.
- At its core, PGP works on a hybrid cryptographic method that combines symmetric-key and public-key cryptography techniques. Symmetric-key cryptography uses one secret key for both encrypting and decrypting data.
- Public-key cryptography uses two keys: a public key (shared with everyone) for encryption and a private key (kept secret) for decryption.

Email Security

- The following are the services offered by PGP:
- 1. Authentication
- 2. Confidentiality
- 3. Email Compatibility
- 4. Segmentation
- **Authentication in PGP**
- Authentication means something that is used to validate something as true or real.
- To login into some sites sometimes we give our account name and password, that is an authentication verification procedure.
- In the email world, checking the authenticity of an email is nothing but to check whether it actually came from the person it says.
- In emails, authentication has to be checked as there are some people who spoof the emails or some spams and sometimes it can cause a lot of inconvenience.

Email Security

- **At the Sender's End:**
- A **hash function (SHA-1)** generates a **160-bit hash value** of the message.
- This hash is **encrypted with the sender's private key (KPa)**, creating a **digital signature**.
- The **message is appended to the signature**, compressed, and sent to the receiver.
- **At the Receiver's End:**
- The message is **decompressed**, and the signature is **decrypted using the sender's public key (PUa)** to retrieve the hash.
- The message is **hashed again** using the same function.
- If both hash values match, the message is verified as authentic and unaltered.
- If not, the message is likely tampered with or from an untrusted source.

Email Security

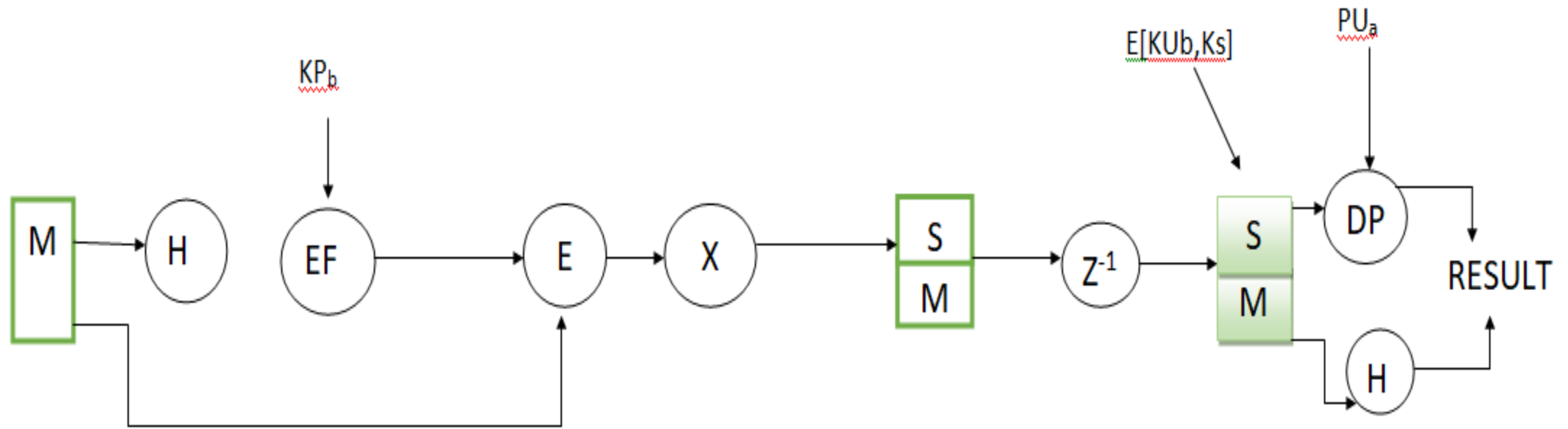


Fig: Authentication in PGP

Email Security

- **Confidentiality in PGP**
- Sometimes we see some packages labelled as 'Confidential', which means that those packages are not meant for all the people and only selected persons can see them.
- The same applies to the email confidentiality as well.
- Here, in the email service, only the sender and the receiver should be able to read the message, that means the contents have to be kept secret from every other person, except for those two.

Email Security

- **How PGP Provides Confidentiality:**
- The message is **compressed and encrypted** using a **random session key (Ks)** with **symmetric encryption (CAST-128, IDEA, or 3DES)**.
- The session key (Ks) is then **encrypted using the receiver's public key (Pub)** with **RSA encryption**.
- The **encrypted message and encrypted session key** are sent together to the receiver.
- **At the Receiver's End:**
- The **session key is decrypted** using the receiver's private key (KPb).
- The **message is decrypted** using the retrieved session key.
- Finally, the message is **decompressed** to restore the original content.
- Since the session key is transmitted in **encrypted form** even if intercepted, it remains unreadable without the private key (KPb).

Email Security

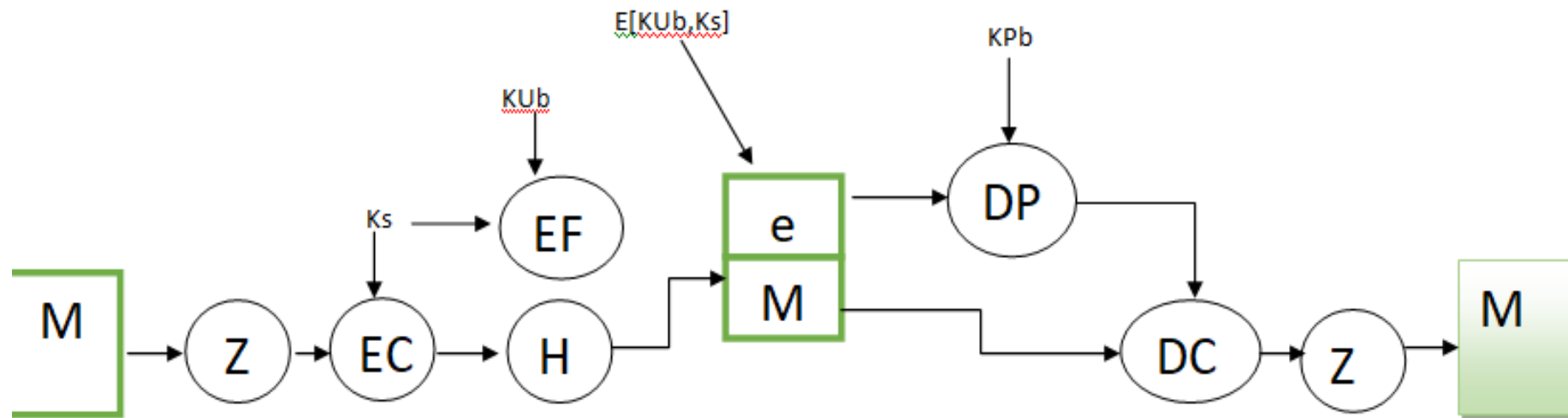
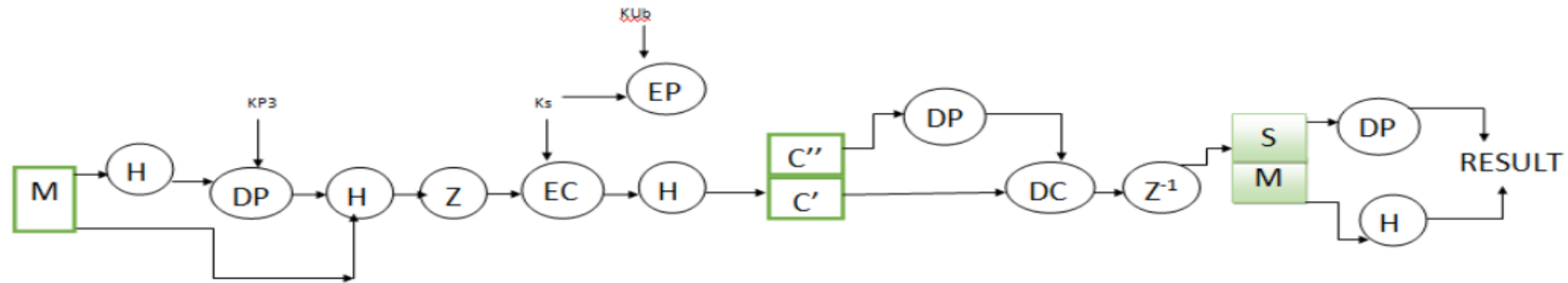


Fig: Confidentiality in PGP

Email Security

Authentication and Confidentiality Together

Practically, **both** the Authentication and Confidentiality services are provided in parallel as follows :



Authentication and Confidentiality services in PGP

Key Terms:

- M – Message
- H – Hash Function
- K_s – Session Key (for Symmetric Encryption)
- KP_a, KP_b – Private Keys of Sender (A) and Receiver (B)
- PU_a, PU_b – Public Keys of Sender (A) and Receiver (B)
- EC / DC – Symmetric Encryption & Decryption Algorithms
- EP / DP – Public Key Encryption & Decryption Algorithms
- $||$ - Concatenation
- Z / Z^{-1} – Compression & Decompression Functions

Email Security

- **Why Authentication and Confidentiality are important in PGP?**
- Together, authentication and confidentiality in PGP set up a stable framework for relied on conversation, allowing individuals and corporations to change information confidentially and securely while keeping privacy and integrity.
- **Advantages of PGP**
- The primary benefit of PGP encryption lies in its unbreakable algorithm.
- It is regarded as a top technique for improving cloud security and is frequently utilized by users who need to encrypt their private conversations.
- This is due to PGP's ability to prevent hackers, governments from accessing files or emails that are encrypted with PGP.

Email Security

- **Disadvantage of PGP**
- The main drawback of PGP encryption is that it is usually not intuitive to use.
- PGP requires time and effort to fully encrypt data and files, which might make messaging more difficult for users.
- If an organization is thinking about deploying PGP, it has to train its employees.
- It is imperative that users comprehend the intricacies of the PGP system to prevent unintentionally weakening their security measures.
- This may occur from using PGP incorrectly or from losing or corrupting keys, endangering other users in situations where security is at an extreme.
- PGP encrypts user messages but does not provide users with any anonymity.
- This makes it possible to identify the source and recipient of emails sent using a PGP solution.

Email Security

- **What is S/MIME?**
- S/MIME stands for Secure/Multipurpose Internet Mail Extensions.
- Through encryption, S/MIME offers protection for business emails.
- S/MIME comes under the concept of Cryptography.
- S/MIME is a protocol used for encrypting or decrypting digitally signed E-mails.
- This means that users can digitally sign their emails as the owner(sender) of the e-mail.
- Emails could only be sent in NVT 7-bit format in the past, due to which images, videos, or audio were not a part of e-mail attachments.
- Bell Communications launched the MIME standard protocol in 1991 to increase the email's restricted functionality.

Email Security

- S/MIME is an upgrade of MIME (Multipurpose Internet Mail Extensions). Due to the limitations of MIME, S/MIME came into play.
- S/MIME is based on asymmetric cryptography which means that communications can be encrypted or decrypted using a pair of related keys namely public and private keys.
- **How S/MIME Works**
- S/MIME enables non-ASCII data to be sent using Secure Mail Transfer Protocol (SMTP) via email.
- Moreover, many data files are sent, including music, video, and image files.
- This data is securely sent using the encryption method.
- The data which is encrypted using a public key is then decrypted using a private key which is only present with the receiver of the E-mail.
- The receiver then decrypts the message and then the message is used. In this way, data is shared using e-mails providing an end-to-end security service using the cryptography method.

Email Security

- **Advantages of S/MIME**

- It offers verification.
- It offers integrity to the message.
- By the use of digital signatures, it facilitates non-repudiation of origin.
- It offers seclusion.
- Data security is ensured by the utilization of encryption.
- Transfer of data files like images, audio, videos, documents, etc. in a secure manner.

Email Security

- **Services of S/MIME**
- S/MIME (Secure/Multipurpose Internet Mail Extensions) is used to secure email communication by providing encryption, authentication and digital signatures. Here are some real-life applications:
- **Corporate Email Security:** Protects sensitive business communications, ensuring confidentiality and authenticity through digital signatures and encryption.
- **Government Agencies:** Secures communication of classified information and validates legal documents.
- **Legal Sector:** Secures legal document exchanges and provides digital signatures for authenticity.
- **Cross-Border Communication:** Secures international business and government communication.
- **Personal Email Security:** Individuals use S/MIME to secure personal communications and private data.
- **Cybersecurity:** Helps prevent phishing and email spoofing by verifying the authenticity of emails.

Email Security

PGP	S/MIME
PGP stands for Pretty Good Privacy.	S/MIME stands for Secure/Multipurpose Internet Mail Extension.
It can be used by individuals and corporations.	It is used by corporations or for commercial purposes.
PGP is a general purpose application to protect files and used for email security.	S/MIME is used for email security.
Diffie Hellman digital signature is used.	Elgamal digital signature is used.
PGP is a data encryption and decryption computer program that offers cryptographic privacy and authentication for internet data transmission.	S/MIME provides the authentication, message integrity and non-repudiation of origin and data security services for electronic data transmission applications.
PGP was designed to eliminate security issues of text messages.	S/MIME was designed to provide security for attachments and data files.
PGP products are costlier than S/MIME.	S/MIME products are cheaper than PGP.

THANK YOU